

BOLA / IDOR — osTicket ajax.tickets.php

Date	March 27, 2026	Severity	HIGH — CVSS 4.0: 8.2
Researcher	@JF0x0r	Target	osTicket
Component	include/ajax.tickets.php	Function	viewField() — lines 805–806
CWE	CWE-862 (Missing Authorization), CWE-639 (Auth Bypass via User-Controlled Key)		

01 · CVSS 4.0 SCORE

8.2	HIGH CVSS v4.0	Vector String: CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N
-----	-------------------	---

Metric	Value	Justification
Attack Vector (AV)	Network (N)	Exploitable remotely over HTTP; no physical access required
Attack Complexity (AC)	Low (L)	No special conditions; a standard authenticated session suffices
Attack Requirements (AT)	None (N)	No prerequisites beyond a valid agent credential
Privileges Required (PR)	Low (L)	Requires only a low-privileged authenticated agent account
User Interaction (UI)	None (N)	No victim interaction needed; fully attacker-driven
Vuln. Confidentiality (VC)	High (H)	Full read access to any ticket field across all departments
Vuln. Integrity (VI)	None (N)	viewField() is read-only; no data modification occurs
Vuln. Availability (VA)	None (N)	No denial of service impact observed
Subsequent (SC/SI/SA)	None (N)	Impact confined to the vulnerable system scope

02 · DESCRIPTION

A **Broken Object Level Authorization (BOLA)** — also known as **Insecure Direct Object Reference (IDOR)** — vulnerability was identified in the osTicket AJAX ticket management subsystem. The vulnerability resides specifically in the `viewField()` function within `include/ajax.tickets.php`, at lines 805–806.

The function correctly retrieves the ticket object and validates field existence, but **entirely omits the standard authorization check** (`$ticket->checkStaffPerm($thisstaff)`) that would prevent unauthorized cross-departmental access. As a result, any authenticated agent — regardless of their assigned department — can read arbitrary ticket fields belonging to departments they are explicitly excluded from.

The exposed endpoint is:

```
GET /scp/ajax.php/tickets/{ticket_id}/field/{field_id}/view
```

03 · VULNERABLE CODE — VIEWFIELD() LINES 805–806

The following screenshot shows the vulnerable function as found in `include/ajax.tickets.php`. At line 805, the `elseif` condition directly calls `$ticket->getField($fid)` without a preceding permission verification. The inline comment in the code confirms the exact location of the flaw.

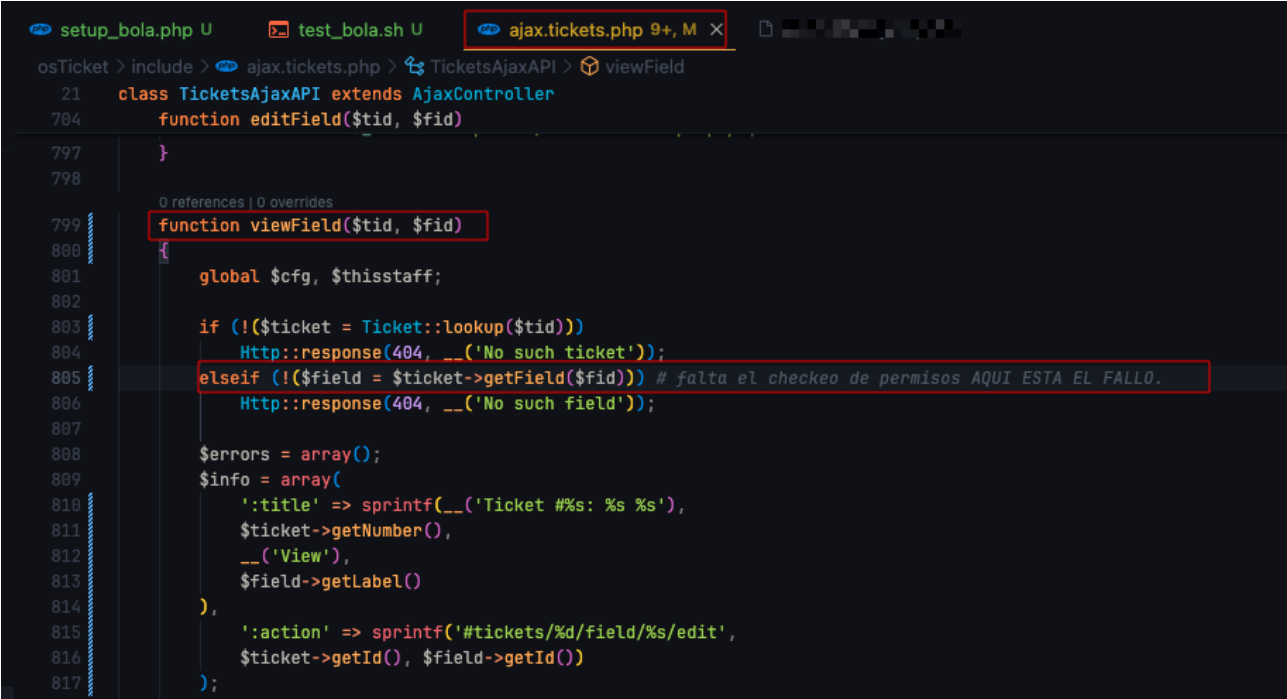


Figure 1 — `viewField()` in `ajax.tickets.php`: missing `checkStaffPerm()` check (line 805)

Note the inline comment on line 805: *"# falta el chequeo de permisos AQUI ESTA EL FALLO"* (missing permission check — HERE IS THE BUG). The function proceeds to expose ticket field data without validating whether the requesting agent has departmental access to the ticket.

04 · CORRECT IMPLEMENTATION — EDITFIELD() COMPARISON

The sibling function `editField()`, located in the same file, correctly implements the authorization check. Immediately after retrieving the ticket object, it calls `$ticket->checkStaffPerm($thisstaff, Ticket::PERM_EDIT)`, which returns **HTTP 403 — Permission denied** when the requesting agent lacks access. This confirms the omission in `viewField()` is an inconsistency, not an intentional design choice.

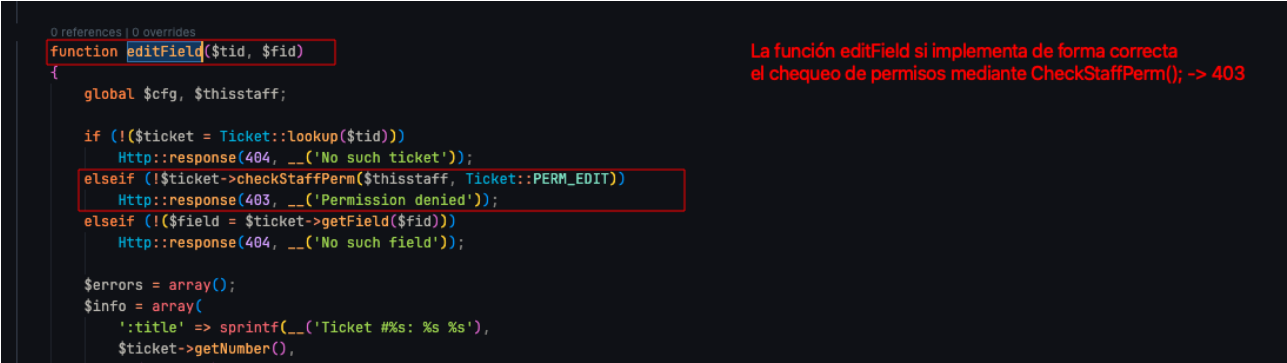


Figure 2 — `editField()` correctly calls `checkStaffPerm()` and returns HTTP 403 on violation

Function	checkStaffPerm() Present	Unauthorized Access Result
editField(\$tid, \$fid)	Yes	HTTP 403 — Permission denied
viewField(\$tid, \$fid)	NO — MISSING	HTTP 200 — Data exposed

05 · IMPACT

Sensitive Data Disclosure	Confidential metadata, customer discussions, and specialized ticket fields are readable by any agent.
Horizontal Privilege Escalation	Agents can bypass their assigned departmental boundaries without any administrative action or approval.
Ticket Enumeration	Sequential iteration over <code>ticket_id</code> and <code>field_id</code> parameters allows bulk scraping of the entire platform.
Multi-tenant Confidentiality Breach	Defeats the core <code>osTicket</code> design principle of department-level data isolation.

06 · RECOMMENDED REMEDIATION

The fix requires a single additional authorization check inside `viewField()`, immediately after the ticket object is retrieved. The check should invoke `$ticket->checkStaffPerm($thisstaff)` and return **HTTP 403** on failure — identical to the pattern already implemented in `editField()`.

Secondary recommendations:

- **Audit sibling AJAX methods:** Systematically review all methods within `AjaxController` classes for missing `checkStaffPerm()` calls.
- **Centralize authorization logic:** Combine `Ticket::lookup()` and permission assertion into a single authorization-aware pipeline to prevent future regression.
- **Automated testing:** Add cross-department access assertions to the CI/CD pipeline for all AJAX read/write endpoints.